

Secretaria Municipal de Saúde

Política Unificada de Segurança e Privacidade da Informação

HISTÓRICO DE VERSÕES E CONTROLE DOCUMENTAL

Versão atual:	1.0
Data de emissão:	11/06/2026
Autoria:	Núcleo de Tecnologia da Informação Comitê de Segurança da Informação e Privacidade
Aprovações:	Dra. Mariana Souza Cavalcanti — Secretária Municipal de Saúde Beatriz Mendes Fontes — Presidente do Comitê de Segurança da Informação e Privacidade Amanda Rodrigues Rocha — Gerente de Tecnologia da Informação (Sec. Municipal de Saúde) Dr. Roberto Alencar Prado — Chefe da Assessoria Jurídica (Sec. Municipal de Saúde)
Data de vigência:	A partir de 15/06/2026
Data de expiração/revisão obrigatória:	15/06/2028

ÍNDICE

1 DISPOSIÇÕES GERAIS E ESCOPO AMPLIADO.....	7
1.1 Objetivo, Diretrizes Primordiais e Alinhamento Estratégico.....	7
1.2 Fundamentação Legal, Normativa e Acoplamento Técnico.....	7
1.2.1 Lei Federal nº 13.709/2018 (Lei Geral de Proteção de Dados Pessoais - LGPD).....	8
1.2.2 Programa de Privacidade e Segurança da Informação (PPSI 2.0).....	8
1.2.3 ABNT NBR ISO 31000 (Gestão de Riscos – Diretrizes).....	8
1.2.4 ABNT NBR ISO/IEC 27005 (Segurança da Informação, Segurança Cibernética e Proteção à Privacidade – Orientações para Gestão de Riscos de Segurança da Informação).....	9
1.2.5 ABNT NBR ISO/IEC 27557 (Segurança da Informação, Segurança Cibernética e Proteção da Privacidade – Aplicação da ISO 31000 para Gestão de Riscos de Privacidade Organizacional).....	9
1.2.6 NIST SP 800-88 (Guidelines for Media Sanitization).....	10
1.3 Escopo de Aplicação e Abrangência.....	10
1.3.1 Corpo Funcional e Agentes Públicos Internos.....	10
1.3.2 Mão de Obra e Prestadores de Serviços Terceirizados.....	10
1.3.3 Provedores de Plataformas Tecnológicas e Engenharia de Software....	11
1.3.4 Operadores Logísticos e Gestores da Cadeia de Suprimentos.....	11
1.3.5 Entidades, Clínicas e Estabelecimentos Privados Conveniados.....	11
1.4 Matriz e Tabela de Gestão de Riscos de Segurança e Privacidade.....	12
1.4.1 Critérios de Avaliação (Matriz de Risco).....	12
1.4.2 Tabela de Riscos e Controles Mitigatórios.....	13
2 GOVERNANÇA E GESTÃO DE RISCOS DE SEGURANÇA E PRIVACIDADE... 15	15
2.1 Estrutura de Governança e Papéis Responsáveis.....	15
2.2 Metodologia de Análise e Gestão de Riscos (ISO 31000, 27005 e 27557)....	15
2.3 Programa de Conscientização e Enfrentamento à Baixa Cultura de Segurança.....	16
3 CONTROLE DE ACESSO LÓGICO E SEGURANÇA DE INFRAESTRUTURA... 18	18
3.1 Identificação, Autenticação e Uso de Dispositivos.....	18
3.2 Controle de Permissões em Pastas e Arquivos de Rede.....	18
3.3 Políticas de Navegação na Internet e Uso do E-mail Corporativo.....	19
3.3.1 Uso de Redes Sociais por Servidores Públicos.....	20
3.4 Perfis de Acesso Hierárquico no Sistema de Informação em Saúde.....	20
3.5 Política de Acesso Remoto à Rede Municipal via VPN (Virtual Private Network).....	21
3.6 Ativação e Homologação de Estações de Trabalho Externas para o Sistema de Saúde.....	22
4 SEGURANÇA DAS COMUNICAÇÕES, INTEROPERABILIDADE E COMPARTILHAMENTO DE DADOS.....	24

4.1 Compartilhamento de Dados na Rede Pública (Relações Público-Público)...	24
4.2 Fluxo de Dados com Entidades e Laboratórios Conveniados (Relações Público-Privado).....	24
4.3 Segurança da Informação na Cadeia de Suprimentos e Logística.....	25
5 SEGURANÇA FÍSICA DAS INSTALAÇÕES E GESTÃO DE DOCUMENTOS NÃO DIGITAIS.....	27
5.1 Controle de Acesso às Áreas Críticas de Infraestrutura de TI.....	27
5.2 Segurança Ambiental nas Áreas de Atendimento ao Público.....	28
5.3 Manuseio, Transporte e Descarte Seguro de Documentos.....	28
6 GESTÃO DE INCIDENTES DE SEGURANÇA E PLANOS DE CONTINUIDADE DE NEGÓCIOS.....	30
6.1 Identificação, Notificação e Resposta a Incidentes Cibernéticos.....	30
6.2 Fluxo Legal de Comunicação de Vazamento de Dados.....	30
6.3 Plano de Continuidade Operacional em Saúde.....	31
6.4 Processo de Retroalimentação e Recuperação do Sistema Pós-Incidente...	32
7 GESTÃO DE FORNECEDORES, TERCEIROS E CONTRATOS.....	34
7.1 Requisitos de Segurança para o Fornecedor do Aplicativo de Saúde.....	34
7.2 Responsabilidade Solidária de Empresas de Serviços Terceirizados.....	34
7.3 Segurança de Dados no Compartilhamento com Laboratórios e Clínicas Conveniadas.....	35
7.4 Direito de Auditoria e Fiscalização Contratual (Right to Audit).....	36
8 MONITORAMENTO, AUDITORIA E TRILHA DE LOGS INTERNOS.....	37
8.1 Obrigatoriedade do Registro de Eventos (Trilha de Auditoria).....	37
8.2 Retenção, Guarda e Imutabilidade dos Arquivos de Log.....	38
8.3 Rotinas de Análise e Monitoramento de Anomalias.....	39
8.4 Prerrogativa de Investigação e Quebra de Sigilo Interno.....	40
9 DIRETRIZES DE CONFORMIDADE, VIOLAÇÕES E PENALIDADES.....	42
9.1 Finalidade e Objetivo.....	42
9.2 Da Obrigatoriedade da Ciência (Garantia de Aplicabilidade).....	42
9.3 Classificação das Infrações.....	42
9.4 Das Penalidades Aplicáveis.....	43
9.4.1 Para Servidores Públicos (Estatutários e Comissionados).....	43
9.4.2 Para Estagiários.....	44
9.4.3 Para Empresas Terceirizadas e Prestadores de Serviço.....	44
9.5 Responsabilização Civil e Penal.....	44
10 DISPOSIÇÕES FINAIS.....	46
10.1 Atualização e Revisão Periódica.....	46
10.2 Casos Omissos.....	46
ANEXO A – Modelo de Termo de Ciência e Responsabilidade.....	47
ANEXO B – Glossário Técnico e Legal.....	49

CONTEXTUALIZAÇÃO

A Secretaria Municipal de Saúde (SMS) em análise atua como o órgão gestor do Sistema Único de Saúde (SUS) em um município de médio porte, localizado na região norte do estado de Santa Catarina. A estrutura administrativa e assistencial gerida pela SMS é vasta, descentralizada e ininterrupta, englobando as diretorias de Vigilância (Epidemiológica, Sanitária, Ambiental e Saúde do Trabalhador), dezenas de Unidades Básicas de Saúde (UBS), Unidades de Pronto Atendimento (UPA), um Hospital Municipal e um Laboratório Municipal de análises clínicas. Diferente de modelos estruturais centralizados, a dispensação de medicamentos à população ocorre de forma pulverizada, com farmácias integradas diretamente nas UBSs, nas UPAs e no próprio complexo hospitalar municipal. Essa capilaridade, embora excelente para o acesso do cidadão, multiplica os terminais físicos e os pontos de acesso lógico a dados sensíveis de pacientes crônicos e agudos.

Para orquestrar essa complexa rede de assistência, o município não utiliza um software de desenvolvimento próprio, mas sim um sistema informatizado de gestão em saúde fornecido por uma empresa privada. Este ecossistema tecnológico abarca os prontuários eletrônicos, as agendas de consultas, o histórico de dispensação das farmácias e os registros de enfermagem. Além de coordenar os atendimentos da rede própria, a SMS exerce um papel regulatório governamental fundamental: é o órgão responsável por auditar e aprovar os trâmites burocráticos para o cadastro e a habilitação de clínicas e hospitais particulares locais no Cadastro Nacional de Estabelecimentos de Saúde (CNES), o que exige o recebimento e o tráfego seguro de informações corporativas e dados de profissionais de saúde dessas instituições privadas.

A logística de suprimentos adiciona outra camada de criticidade ao controle de informações do órgão. Como a prefeitura não mantém um Centro de Distribuição (CDD) próprio de grande porte, o fluxo do almoxarifado central — por onde ingressam praticamente todos os insumos médicos, medicamentos e materiais utilitários — é viabilizado por meio de contratos com empresas privadas de logística e distribuição. Paralelamente, a prestação contínua de serviços de média e alta complexidade exige uma logística rigorosa de regulação de pacientes. Quando a

rede pública de saúde da região (em âmbito municipal, estadual ou federal) não oferece determinado serviço especializado ou não possui capacidade imediata de atendimento, a SMS recorre a convênios com hospitais particulares, clínicas e laboratórios privados locais. Além disso, mesmo quando o atendimento é absorvido pelo próprio Sistema Único de Saúde (SUS), o encaminhamento de um munícipe para um hospital de referência gerido pelo Governo do Estado ou pela União configura o compartilhamento de dados sensíveis entre entes governamentais distintos. Todo esse ecossistema exige o tráfego contínuo de guias, requisições de exames, laudos e históricos clínicos, demandando interoperabilidade e trânsito seguro de informações tanto com a iniciativa privada quanto com outras esferas do poder público.

Diante desta arquitetura operacional, o fluxo de dados do município transita por uma pluralidade de atores: servidores estatutários e comissionados/temporários, estagiários, médicos plantonistas, recepcionistas terceirizados com alta rotatividade, empresas fornecedoras de software, operadores logísticos e instituições privadas conveniadas. Consequentemente, a superfície de exposição a riscos cibernéticos, como o vazamento de informações sensíveis, o uso indevido de credenciais e a falha na proteção da privacidade dos cidadãos, é altíssima. A formulação desta Política de Segurança da Informação e Privacidade torna-se, portanto, imperativa para padronizar controles de acesso, mitigar vulnerabilidades causadas por uma baixa cultura de segurança e garantir a continuidade dos serviços essenciais à vida da população.

1 DISPOSIÇÕES GERAIS E ESCOPO AMPLIADO

1.1 Objetivo, Diretrizes Primordiais e Alinhamento

Estratégico

Esta Política Unificada de Segurança da Informação (PSI) e de Privacidade de Dados Pessoais (PPDP) estabelece o framework estratégico, as diretrizes normativas e os controles operacionais e tecnológicos destinados a assegurar a proteção contínua dos ativos de informação e a salvaguarda integral dos direitos fundamentais de liberdade, intimidade e privacidade dos cidadãos. O propósito central deste documento é mitigar a superfície de ataque cibernético, padronizar os processos de tratamento de dados e garantir a conformidade legal da Secretaria Municipal de Saúde (SMS).

Considerando a criticidade das operações de saúde em um município de médio porte, onde o fluxo assistencial é ininterrupto e descentralizado, esta política atua como o pilar de governança que equilibra a necessidade de compartilhamento ágil de informações clínicas com o dever absoluto de confidencialidade. As diretrizes aqui dispostas visam proteger a infraestrutura tecnológica contra incidentes, conscientizar o corpo funcional contra vulnerabilidades comportamentais e blindar o ecossistema de saúde municipal contra ameaças que possam comprometer a continuidade dos serviços essenciais à vida da população.

1.2 Fundamentação Legal, Normativa e Acoplamento

Técnico

A arquitetura desta Política foi inteiramente modelada com base nas legislações federais vigentes e nos mais rigorosos padrões internacionais de segurança e privacidade, garantindo simetria técnica com o estado da arte em governança de dados públicos. O arcabouço normativo que sustenta este documento é composto por:

1.2.1 Lei Federal nº 13.709/2018 (Lei Geral de Proteção de Dados Pessoais - LGPD)

Vetor legal que baliza os princípios de finalidade, adequação, necessidade, livre acesso, qualidade dos dados, transparência, segurança, prevenção, não discriminação e responsabilização no tratamento de dados de saúde.

A conformidade da Secretaria Municipal de Saúde (SMS) com este dispositivo é assegurada através da implementação estrita dos preceitos do Art. 5º, inciso II, que qualifica os dados de saúde como sensíveis, exigindo controles reforçados. Esta política atende aos requisitos legais ao estabelecer o fluxo de tratamento de dados, a nomeação do Encarregado (DPO) e a garantia de que as operações de saúde, desde a recepção até a regulação, operem sob o princípio da minimização de dados e transparência com o titular.

1.2.2 Programa de Privacidade e Segurança da Informação (PPSI 2.0)

Modelo de governança digital instituído pelo Governo Federal brasileiro, adotado por esta SMS para parametrizar os níveis de maturidade institucional, controles de conformidade e o ciclo de vida da segurança cibernética na administração pública.

Este programa provê os indicadores de desempenho e os requisitos mínimos para que a SMS estruture seus planos de mitigação de riscos. A política adere a este framework ao adotar os modelos de governança sugeridos para a administração pública, assegurando que as ações da SMS estejam alinhadas às estratégias nacionais de governo digital, garantindo a interoperabilidade e a segurança das comunicações.

1.2.3 ABNT NBR ISO 31000 (Gestão de Riscos – Diretrizes)

Norma macro que estabelece os princípios gerais e o fluxo organizacional para a identificação, análise, avaliação, tratamento e monitoramento de riscos em nível institucional, permitindo que a liderança da SMS tome decisões baseadas em riscos.

Em conformidade com a Seção 5 da norma, que trata da estrutura (framework) de gestão de riscos, esta política estabelece o Comitê de Segurança da Informação e Privacidade (CSIP) como o corpo responsável pela liderança e comprometimento, garantindo que a gestão de riscos seja integrada a todos os processos da Secretaria, da logística de insumos ao atendimento clínico.

1.2.4 ABNT NBR ISO/IEC 27005 (Segurança da Informação, Segurança Cibernética e Proteção à Privacidade – Orientações para Gestão de Riscos de Segurança da Informação)

Norma técnica especializada utilizada para operacionalizar o mapeamento de ameaças específicas à infraestrutura de TI, vulnerabilidades de sistemas de saúde e critérios de impacto à confidencialidade, integridade e disponibilidade dos dados digitais e físicos.

Esta política alinha-se a esta norma ao adotar o processo de gestão de riscos de SI descrito em suas cláusulas, aplicando-o ao software de gestão em saúde da SMS. Isso garante que a identificação de ameaças (como ataques a servidores) e a avaliação de vulnerabilidades (como a gestão de acessos via VPN) sejam tratadas tecnicamente para mitigar a probabilidade de falhas de segurança.

1.2.5 ABNT NBR ISO/IEC 27557 (Segurança da Informação, Segurança Cibernética e Proteção da Privacidade – Aplicação da ISO 31000 para Gestão de Riscos de Privacidade Organizacional)

Norma crítica aplicada especificamente para conectar a gestão de riscos tradicional ao impacto real que um vazamento ou tratamento inadequado de dados pode causar na vida e na dignidade do cidadão (titular dos dados), fornecendo a metodologia para as avaliações de impacto à privacidade (RIPD/PIA) dentro do cenário da saúde pública municipal.

A conformidade com esta norma é demonstrada por meio da implementação dos Relatórios de Impacto à Proteção de Dados Pessoais (RIPD) previstos nesta política, permitindo à SMS avaliar as consequências de incidentes na vida do

paciente e justificar os investimentos em controles mitigatórios específicos para a privacidade.

1.2.6 NIST SP 800-88 (Guidelines for Media Sanitization)

Diretriz internacionalmente reconhecida para o descarte e sanitização segura de mídias de armazenamento, utilizada como referência para a destruição de dados em desuso na rede de saúde. A política incorpora este padrão no subitem 5.3, que proíbe o descarte comum de equipamentos e exige procedimentos de destruição física ou desmagnetização. Ao seguir os níveis de sanitização propostos pelo NIST SP 800-88, a SMS garante que dados sensíveis de prontuários e históricos médicos não sejam recuperáveis após o ciclo de vida útil dos equipamentos de TI, cumprindo o requisito de segurança no descarte determinado pela LGPD.

1.3 Escopo de Aplicação e Abrangência

A abrangência desta política é universal e irrestrita dentro do ecossistema de saúde do município. Suas determinações vinculam, sem exceção, todos os atores que possuam acesso físico ou lógico aos sistemas, dependências ou ativos de informação da SMS, divididos nas seguintes categorias:

1.3.1 Corpo Funcional e Agentes Públicos Internos

Aplica-se a todos os servidores públicos estatutários (concursados), ocupantes de cargos em comissão, contratados por tempo determinado (temporários), equipes de residentes médicos e multiprofissionais, estagiários e autoridades políticas em exercício na estrutura da SMS. O escopo geográfico e operacional cobre todas as frentes assistenciais e regulatórias, incluindo as Unidades Básicas de Saúde (UBS), Unidades de Pronto Atendimento (UPA), Hospital Municipal, Laboratório Municipal de Análises Clínicas e as Diretorias de Vigilância Epidemiológica, Sanitária, Ambiental e da Saúde do Trabalhador.

1.3.2 Mão de Obra e Prestadores de Serviços Terceirizados

Aplica-se integralmente aos colaboradores vinculados a empresas privadas prestadoras de serviços que atuam sob o regime de terceirização nas dependências

da secretaria. Esta categoria exige atenção especial devido à alta rotatividade de pessoal e ao contato direto com o cidadão, englobando as equipes de recepção, triagem administrativa pré-clínica, vigilância e segurança física patrimonial, equipes de higienização hospitalar e auxiliares de suporte técnico operacional de TI.

1.3.3 Provedores de Plataformas Tecnológicas e Engenharia de Software

Aplica-se de forma mandatória às pessoas jurídicas de direito privado contratadas para o fornecimento, desenvolvimento, manutenção, hospedagem em nuvem ou suporte dos sistemas informatizados de gestão em saúde. Estas empresas são classificadas tecnicamente como Operadoras de Dados e estão estritamente vinculadas aos níveis de segurança estipulados nesta política através de cláusulas contratuais acessórias de confidencialidade e SLA.

1.3.4 Operadores Logísticos e Gestores da Cadeia de Suprimentos

Aplica-se às empresas privadas integradas à cadeia logística da saúde municipal, responsáveis pela operação, armazenamento, inventariado e distribuição física dos materiais que tramitam pelo Almoxarifado Central. O escopo abrange o transporte de medicamentos de alto custo, insumos hospitalares, fórmulas nutricionais e utilitários da saúde, cujos romaneios e guias de entrega frequentemente contêm dados nominativos e endereços de pacientes atendidos por programas de assistência domiciliar.

1.3.5 Entidades, Clínicas e Estabelecimentos Privados Conveniados

Aplica-se a todos os hospitais filantrópicos ou privados, clínicas de especialidades médicas e laboratórios de análises privados da região que mantenham termos de convênio, contratos de credenciamento ou parcerias de prestação de serviços com o município para absorver a demanda regulada de consultas, exames e tratamentos de média e alta complexidade. A vinculação a esta política estende-se, ainda, às instituições privadas que submetem seus cadastros e corpos profissionais à validação da SMS para fins de regularização perante o Cadastro Nacional de Estabelecimentos de Saúde (CNES).

1.4 Matriz e Tabela de Gestão de Riscos de Segurança e Privacidade

Esta seção consolida a Matriz e a Tabela de Gestão de Riscos da Secretaria Municipal de Saúde, alinhando as diretrizes de segurança e privacidade aos padrões normativos. Seu objetivo é mapear as principais ameaças enfrentadas pelo órgão público e estabelecer controles mitigatórios rigorosos, garantindo a proteção contínua dos dados sensíveis dos cidadãos e a conformidade legal.

1.4.1 Critérios de Avaliação (Matriz de Risco)

A avaliação dos riscos baseia-se na combinação entre a Probabilidade (chance do evento ocorrer) e o Impacto (consequências para o cidadão e para a SMS, incluindo sanções legais e danos à reputação).

Probabilidade	Impacto	Nível de Risco	Ação Exigida
Alta	Alto	Crítico	Mitigação imediata com controles técnicos bloqueantes.
Média	Alto	Alto	Implementação de controles técnicos e administrativos e monitoramento contínuo.
Alta	Médio	Alto	Treinamento obrigatório, revisão de processos e auditoria.
Média	Médio	Médio	Controles procedimentais e conscientização periódica.

Baixa	Baixo	Baixo	Aceitação tolerável com monitoramento de rotina.
-------	-------	-------	--

1.4.2 Tabela de Riscos e Controles Mitigatórios

A tabela a seguir mapeia os riscos específicos ao ecossistema de saúde pública do município e as exigências normativas para sua mitigação.

ID	Ameaça / Vulnerabilidade	Probabilidade	Impacto	Nível de Risco	Controle Mitigatório Exigido (Política Aplicada)
R01	Uso Indevido de Sistemas (Acesso Excessivo) Servidores ou terceirizados acessando prontuários de pacientes fora de sua atribuição clínica.	Alta	Alto	Crítico	Controle de Acesso Hierárquico: Aplicação do princípio do menor privilégio. Perfis administrativos/recepção têm acesso apenas a dados cadastrais. Perfis assistenciais acessam dados clínicos. Uso de Trilha de Auditoria (Logs) obrigatória.
R02	Vazamento de Informações Sensíveis (Interceptação) Tráfego e guarda de dados de saúde (CID's, exames) em texto claro no banco de dados ou no envio para clínicas conveniadas.	Média	Alto	Alto	Armazenamento e Tráfego Criptografado: Exigência de criptografia forte (ex: AES-256) para dados em repouso no servidor da SMS. Tráfego via APIs seguras com protocolo HTTPS para interoperabilidade com parceiros.
R03	Baixa Cultura de Segurança (Senhas Fracas e Compartilhadas) Compartilhamento de credenciais genéricas em recepções de UPAs/UBSs, facilitando invasões.	Alta	Médio	Alto	Política de Senhas e Credenciais Individuais: Proibição de contas genéricas. Login vinculado ao CPF individual. Implementação técnica de troca de senha obrigatória a cada 90 dias. Aplicação de advertência ou suspensão em caso de compartilhamento.
R04	Recuperação de Dados Excluídos (Descarte Inadequado) Descarte de HDDs antigos, computadores ou pendrives contendo histórico de pacientes como lixo eletrônico	Média	Alto	Alto	Descarte Digital Conforme Legislação: Destruição física ou desmagnetização de mídias de armazenamento certificada pelo Núcleo de TI antes do descarte, garantindo a eliminação irreversível segundo a LGPD.

	comum.				
R05	Exposição de Dados por Servidores (Engenharia Social/Redes Sociais) Servidores utilizando a internet da SMS para redes sociais pessoais ou enviando laudos/telas via WhatsApp.	Alta	Médio	Alto	Restrição de Navegação e Redes Sociais: Bloqueio de redes sociais e webmails pessoais via firewall corporativo. Tipificação do envio de dados por redes sociais como infração grave (sujeita a Demissão/PAD).
R06	Ransomware / Ataques Cibernéticos / Infecção da rede da SMS paralisando o sistema de dispensação de farmácias e prontuários.	Média	Alto	Alto	Defesa e Contingência: Bloqueio de USBs , isolamento imediato da rede , uso de formulários físicos de contingência (Blocos de Contingência) para garantir a operação ininterrupta do SUS.

2 GOVERNANÇA E GESTÃO DE RISCOS DE SEGURANÇA E PRIVACIDADE

2.1 Estrutura de Governança e Papéis Responsáveis

Para garantir que as diretrizes desta política sejam cumpridas na rotina da Secretaria Municipal de Saúde (SMS), fica estabelecida uma estrutura de governança dividida em duas frentes complementares:

- **Comitê de Segurança da Informação e Privacidade (CSIP):** Grupo multidisciplinar formado por representantes fixos das áreas de Tecnologia da Informação (TI), Gestão Administrativa, Diretoria Assistencial (médicos/enfermeiros) e Assuntos Jurídicos da prefeitura. Este comitê tem a responsabilidade de revisar periodicamente as regras de segurança, avaliar relatórios de auditoria do sistema informatizado e coordenar as respostas a eventuais incidentes de segurança.
- **Encarregado pelo Tratamento de Dados Pessoais (DPO - Data Protection Officer):** Profissional formalmente indicado pela SMS que atuará como o canal de comunicação oficial entre o município, os cidadãos (titulares dos dados) e a Autoridade Nacional de Proteção de Dados (ANPD). O DPO também terá o papel de fiscalizar o cumprimento da LGPD tanto internamente quanto nos contratos com empresas parceiras e prestadores terceirizados.

Essa estrutura tem autoridade para auditar o fluxo de dados em todas as frentes da rede municipal, incluindo as recepções terceirizadas das UPAs e UBSs, o almoxarifado central de insumos e as comunicações de exames com laboratórios e hospitais privados conveniados.

2.2 Metodologia de Análise e Gestão de Riscos (ISO 31000, 27005 e 27557)

A SMS adotará um processo contínuo de gestão de riscos para prevenir vulnerabilidades e evitar vazamentos ou interrupções de serviço. Essa metodologia é fundamentada em três normas técnicas complementares:

- **Processo Macrogrencial (ABNT NBR ISO 31000):** Estabelece o fluxo padrão de identificação, análise, tratamento e monitoramento de riscos em toda a secretaria. Toda decisão administrativa ou contratação de novos serviços na saúde deve passar por uma avaliação prévia de riscos.
- **Análise de Riscos Tecnológicos e de TI (ABNT NBR ISO/IEC 27005):** Focada na segurança dos sistemas e da infraestrutura de rede. É utilizada para avaliar vulnerabilidades técnicas, tais como: a segurança dos servidores onde o software de saúde opera, o tráfego seguro de guias e laudos de exames enviados a laboratórios privados e o controle de inventário de medicamentos gerenciado pela empresa de logística do almoxarifado central.
- **Avaliação de Impacto à Privacidade do Cidadão (ABNT NBR ISO/IEC 27557):** Esta norma direciona o olhar do risco para o paciente e para o profissional de saúde. Ela analisa qual o dano moral, social ou de dignidade que um vazamento de dados traria para a pessoa física (por exemplo, a exposição do histórico de medicamentos contínuos retirados na farmácia de uma UBS, que pode revelar diagnósticos sensíveis).

Os resultados dessas análises darão origem ao Relatório de Impacto à Proteção de Dados Pessoais (RIPD), documento que guiará os investimentos em segurança digital da prefeitura.

2.3 Programa de Conscientização e Enfrentamento à Baixa Cultura de Segurança

A falha humana e a falta de informação são as principais causas de incidentes de segurança em órgãos públicos de saúde. Para mitigar o cenário de baixa cultura de segurança e a alta rotatividade de funcionários, a SMS institui as seguintes ações obrigatórias:

- **Treinamento de Onboarding para Terceirizados:** As empresas prestadoras de serviços (especialmente as de recepção e triagem administrativa) ficam obrigadas contratualmente a incluir um módulo de treinamento em segurança da informação e LGPD, validado pela SMS, no processo de integração de

qualquer novo colaborador, antes que este receba suas credenciais de acesso aos sistemas.

- **Campanhas Recorrentes e Atualizações:** Realização de treinamentos rápidos e reciclagem anual para todo o corpo técnico, incluindo servidores concursados, médicos plantonistas e estagiários. O foco dessas ações será combater práticas de risco comuns no dia a dia, como o compartilhamento de senhas pessoais, o abandono de computadores com telas de prontuários logadas e o envio de dados de pacientes por aplicativos de mensagens não oficiais.
- **Formalização de Deveres:** Todo colaborador, interno ou terceirizado, deverá assinar um Termo de Ciência, Confidencialidade e Responsabilidade no início de suas atividades, formalizando o conhecimento sobre as regras de proteção de dados vigentes no município e as sanções em caso de descumprimento.

3 CONTROLE DE ACESSO LÓGICO E SEGURANÇA DE INFRAESTRUTURA

3.1 Identificação, Autenticação e Uso de Dispositivos

O acesso a qualquer computador, notebook, tablet ou terminal de atendimento da Secretaria Municipal de Saúde (SMS) exige a identificação única e individual do usuário. Fica expressamente proibida a criação ou o uso de contas genéricas ou compartilhadas (como "recepcao", "triagem" ou "plantao") para o login nos sistemas operacionais.

- **Credenciais Individuais:** Cada servidor, estagiário ou prestador terceirizado receberá um usuário e senha pessoal e intransferível vinculados ao seu CPF.
- **Bloqueio Automático por Inatividade:** Todas as estações de trabalho localizadas em áreas de atendimento ao público (como recepções de UBSs e UPAs, farmácias e laboratórios) devem ser configuradas com bloqueio automático de tela após, no máximo, 5 minutos de inatividade. Essa medida evita que terceiros visualizem informações na ausência do operador.
- **Gestão de Contas e Desligamento:** O Núcleo de TI, em conjunto com o RH e as empresas terceirizadas, manterá um fluxo de desligamento ágil. Quando um colaborador for exonerado, transferido ou rescindir o contrato (no caso de terceiros), suas credenciais de rede, e-mail e sistemas devem ser revogadas em até 24 horas.

3.2 Controle de Permissões em Pastas e Arquivos de Rede

O armazenamento de documentos digitais (planilhas, relatórios, termos e ofícios) em servidores locais ou em nuvem governamental deve seguir o princípio do menor privilégio. Os usuários só terão acesso às pastas estritamente necessárias para suas funções.

- **Segregação de Pastas:** O servidor de arquivos da SMS será dividido em diretórios restritos por departamento (ex: Recursos Humanos, Vigilância Sanitária, Almoxarifado/Logística, Gestão Financeira).

- **Restrição por Perfil:** Um funcionário alocado na logística do almoxarifado central, por exemplo, terá permissão de leitura e escrita apenas nas pastas de controle de insumos e romaneios, sendo bloqueado de acessar arquivos de prontuários médicos ou dados funcionais de servidores do RH.
- **Auditoria de Arquivos:** Modificações, exclusões ou criações de arquivos sensíveis dentro da rede interna serão registradas em relatórios de auditoria automatizados para permitir a rastreabilidade em caso de vazamento de informações administrativas.

3.3 Políticas de Navegação na Internet e Uso do E-mail Corporativo

Considerando a necessidade de mitigar riscos decorrentes da baixa cultura de segurança da informação, o uso da rede de dados e dos recursos de conectividade da SMS será monitorado e limitado.

- **Filtro de Conteúdo Web:** O Núcleo de TI implementará firewalls com bloqueio de categorias de sites que não possuam relação com a atividade fim da saúde pública (tais como redes sociais, plataformas de streaming, jogos online, serviços de armazenamento de arquivos pessoais e sites de download).
 - **Exceção e Liberação de Acesso:** Em casos de necessidade justificada onde o acesso a um site bloqueado for indispensável para a execução da atividade laboral, o servidor deverá abrir um chamado técnico junto ao Núcleo de TI. O chamado será submetido à avaliação da chefia imediata do solicitante, que validará a pertinência do pedido para o trabalho. Uma vez aprovado, o Núcleo de TI procederá com a liberação temporária ou permanente do acesso ao domínio solicitado.
- **Proteção contra Phishing:** O acesso a webmails pessoais (como Gmail, Outlook ou Yahoo) será bloqueado nos computadores institucionais para evitar a entrada de vírus e ataques de engenharia social. Toda comunicação oficial de trabalho deve tramitar exclusivamente pelo e-mail corporativo da prefeitura ou pelos sistemas oficiais de tramitação de processos.

- **Uso de Dispositivos Removíveis:** Fica restrita a utilização de mídias removíveis não autorizadas (como pendrives e HDs externos particulares) nos computadores da rede de saúde, visando impedir a contaminação da rede por malwares e a cópia indevida de bancos de dados.

3.3.1 Uso de Redes Sociais por Servidores Públicos

É vedada a utilização de dispositivos institucionais (computadores, tablets e smartphones da Secretaria) para o acesso a redes sociais pessoais ou profissionais durante a jornada de trabalho. É expressamente proibida a captura, armazenamento ou postagem de fotos, vídeos ou qualquer registro que exponha o ambiente de trabalho interno, equipamentos de TI, documentos ou pacientes. Esta restrição visa impedir o vazamento acidental de dados sensíveis e a exposição indevida da infraestrutura de saúde

3.4 Perfis de Acesso Hierárquico no Sistema de Informação em Saúde

Dentro dos softwares de gestão, bancos de dados e redes integradas, as permissões de visualização, edição e extração de dados obedecerão estritamente à função profissional de cada agente, dividindo-se nos seguintes perfis:

- **Perfil Administrativo e Recepção (Servidores e Terceirizados):** Acesso limitado ao cadastro básico do cidadão (nome, CPF, endereço, Cartão SUS) para fins de acolhimento, abertura de fichas e agendamento de consultas. Este perfil é completamente bloqueado para visualizar prontuários médicos, diagnósticos (CID), históricos de remédios ou laudos de exames.
- **Perfil Assistencial (Médicos, Enfermeiros, Dentistas e Técnicos):** Acesso integral ao Prontuário Eletrônico do Paciente (PEP), histórico clínico, laudos de exames, evoluções de enfermagem e módulos de prescrição de medicamentos e vacinas.
- **Perfil Farmácia:** Acesso ao cadastro do paciente, ao módulo de validação de receitas e à baixa de estoque de medicamentos no sistema, sendo vedada a

alteração do histórico médico ou a consulta a prontuários que não tenham relação com a dispensação daquela receita.

- **Perfil Faturamento, Auditoria Médica e CNES:** Acesso aos módulos de produção do SUS (SIA e SIHD), ferramentas de auditoria de contas hospitalares e ao sistema de atualização do Cadastro Nacional de Estabelecimentos de Saúde (CNES). Permite visualizar dados de procedimentos realizados para fins de cobrança e prestação de contas aos órgãos federais, mas proíbe a alteração de condutas médicas ou prontuários.
- **Perfil Gestão, Coordenação e Direção (Secretário, Diretores e Chefes de Unidade):** Acesso consolidado a dados estatísticos, relatórios de produtividade, painéis de indicadores epidemiológicos e painéis financeiros de custos da saúde pública. Os ocupantes desses cargos não possuem acesso nativo a prontuários individuais de pacientes, exceto em casos específicos de auditoria formal ou investigação epidemiológica autorizada.
- **Perfil Tecnologia da Informação (Suporte Interno da SMS):** Acesso de nível administrativo (infraestrutura). Os membros do Núcleo de TI possuem permissão para gerenciar contas de usuários, redefinir senhas, monitorar o status do servidor e fazer backups. Contudo, por questões de privacidade, eles não possuem permissão para acessar o conteúdo clínico dos prontuários, e todas as suas ações técnicas devem gerar relatórios de auditoria (logs).
- **Perfil Regulador Externo (Laboratórios, Clínicas e Hospitais Conveniados):** Acesso restrito via chaves de interoperabilidade, permitindo que a entidade privada visualize apenas a guia de autorização de procedimento ou o encaminhamento específico daquele paciente regulado pelo município, sem qualquer acesso ao banco de dados geral da rede de saúde.

3.5 Política de Acesso Remoto à Rede Municipal via VPN (Virtual Private Network)

Por padrão, o acesso às pastas de rede compartilhadas, servidores de arquivos internos, sistemas administrativos de uso comum da prefeitura e intranets é

totalmente bloqueado para conexões externas (fora dos prédios públicos). A liberação de acesso remoto será tratada como exceção e concedida exclusivamente por meio de VPN segura, obedecendo aos seguintes critérios:

- **Público-Alvo e Justificativa:** A concessão de acessos via VPN é restrita a servidores de cargos de alta gestão em viagens oficiais de trabalho (Secretário, Diretores, Gerentes) e a profissionais do Núcleo de TI escalados em regime de plantão de sobreaviso (após o horário comercial, finais de semana, feriados e recessos institucionais) para atendimentos emergenciais.
- **Fluxo Formal de Solicitação e Liberação:** O acesso por VPN não será ativado de forma automática. O processo exige:
 1. Abertura de chamado formal no sistema de chamados da TI pelo usuário.
 2. Justificativa clara da necessidade do acesso fora do ambiente físico.
 3. Validação e assinatura digital da chefia imediata (superior hierárquico) autorizando o pedido.
 4. Análise técnica de viabilidade e impacto de segurança realizada pelo Núcleo de TI antes da liberação do perfil.
- **Segurança da Conexão:** O canal de VPN deve utilizar protocolos de criptografia forte e exigir autenticação multifator (MFA). O perfil configurado para o usuário dará acesso estrito e exclusivo aos recursos necessários para aquela atividade emergencial, sendo revogado automaticamente após o término do período autorizado ou do plantão de sobreaviso.

3.6 Ativação e Homologação de Estações de Trabalho Externas para o Sistema de Saúde

Diferente dos sistemas administrativos, o software de gestão em saúde opera por meio de um aplicativo local instalado, um programa específico que exige comunicação direta com o banco de dados. No entanto, para evitar que funcionários acessem dados sensíveis de pacientes a partir de computadores públicos ou dispositivos pessoais vulneráveis, institui-se a camada de Homologação Geográfica e Digital de Máquinas:

- **Carimbo Digital/Ativação de Dispositivo:** Para que qualquer computador ou notebook consiga abrir a tela de login do sistema de saúde fora da rede física da SMS, a estação de trabalho deve ser previamente ativada e "carimbada" digitalmente pelo Núcleo de TI. Esse processo ocorre por meio da instalação de certificados digitais ou liberação de chaves de hardware exclusivas via chamado técnico.
- **Cenário de Home Office Formal:** A ativação do sistema de saúde em ambientes residenciais só será permitida para servidores em regime de teletrabalho formalmente homologado pela Secretaria, utilizando preferencialmente equipamentos institucionais configurados com antivírus corporativo ativo e regras rígidas de firewall locais.
- **Atividades Externas e Equipamentos sob Empréstimo (Comodato):** Para equipes que realizam atividades de campo — como os agentes da Vigilância Sanitária em vistorias de estabelecimentos ou a Vigilância Epidemiológica em buscas ativas, Agentes Comunitários de Saúde —, o Núcleo de TI disponibilizará dispositivos móveis institucionais (tablets ou notebooks) sob regime de cautela/empréstimo. Esses aparelhos já saem da TI previamente homologados, com conexões móveis seguras e bloqueados para a instalação de aplicativos terceiros, servindo exclusivamente para alimentar os bancos de dados dos sistemas oficiais (SIS) durante a jornada externa.

4 SEGURANÇA DAS COMUNICAÇÕES, INTEROPERABILIDADE E COMPARTILHAMENTO DE DADOS

4.1 Compartilhamento de Dados na Rede Pública (Relações Público-Público)

O encaminhamento de cidadãos da rede municipal de saúde para hospitais de referência geridos pelo Estado ou pela União configura uma transferência externa de dados entre Controladores distintos. Esse fluxo deve seguir critérios rígidos de segurança:

- **Canais Oficiais de Regulação:** Todo o trâmite de históricos clínicos, laudos e guias de encaminhamento deve ocorrer obrigatoriamente por meio dos sistemas oficiais de regulação de leitos e consultas (como o SISREG ou plataformas estaduais integradas). Fica proibido o uso de e-mails institucionais comuns ou aplicativos de mensagens para o envio dessas informações.
- **Interoperabilidade Padronizada:** A integração entre o software municipal e as bases de dados estaduais ou federais (como o e-SUS) deve utilizar APIs (Interfaces de Programação de Aplicações) seguras, baseadas em protocolos de criptografia e chaves de autenticação exclusivas para cada órgão.
- **Minimização de Dados no Trânsito:** No processo de transferência do paciente, a SMS compartilhará apenas as informações estritamente necessárias para a continuidade do cuidado (anamnese, exames recentes e diagnóstico de encaminhamento), omitindo históricos administrativos ou financeiros que não possuam relevância clínica imediata.

4.2 Fluxo de Dados com Entidades e Laboratórios Conveniados (Relações Público-Privado)

Para suprir os vazios assistenciais em exames, consultas e tratamentos de média e alta complexidade, o compartilhamento de guias e laudos com clínicas e laboratórios privados parceiros deve seguir as seguintes diretrizes:

- **Proibição de Comunicação Informal:** Fica expressamente vedado o envio de pedidos de exames, imagens de laudos ou dados cadastrais de munícipes por meio de aplicativos de mensagens de cunho pessoal (como WhatsApp ou Telegram) por parte dos servidores ou terceirizados da recepção.
- **Portais de Acesso Restrito:** O fornecimento de laudos e resultados por parte dos laboratórios privados conveniados deve ser feito por meio de integração direta de sistemas ou por portais web seguros. Esses portais devem exigir criptografia (HTTPS) e autenticação em duas etapas para os profissionais da SMS que forem consultar os resultados.
- **Termos de Responsabilidade em Anexo Contratual:** Todos os contratos e convênios com a iniciativa privada devem conter cláusulas específicas de proteção de dados, onde as clínicas parceiras se comprometem a adotar padrões de segurança idênticos aos da SMS e a descartar os dados dos pacientes após o término do período legal de guarda do prontuário.

4.3 Segurança da Informação na Cadeia de Suprimentos e Logística

A gestão, transporte e distribuição de medicamentos e materiais hospitalares pelo Almoxarifado Central envolvem riscos tanto de privacidade quanto de continuidade do serviço, devendo ser protegidos em duas frentes:

- **Distribuição de Medicamentos e Itens Personalizados (Dados Sensíveis):** Os romaneios de entrega e as listagens de pacientes que recebem insumos de uso contínuo em domicílio (como oxigenoterapia, dietas especiais e fórmulas) devem trafegar em arquivos digitais criptografados. É proibido o compartilhamento dessas listas em formatos abertos com motoristas ou entregadores terceirizados, devendo o acesso ser limitado ao endereço e nome do destinatário.

- **Abastecimento de Insumos Gerais (Disponibilidade e Continuidade):** O sistema de inventário de insumos comuns (como luvas, seringas e medicamentos básicos) que atende as UPAs e UBSs deve possuir cópias de segurança (backups) diárias e isoladas. O controle de estoque é considerado um ativo crítico, pois um ataque cibernético que paralise este sistema causará o desabastecimento imediato da rede assistencial.
- **Segurança de Fornecedores:** As empresas privadas contratadas para operar a logística do almoxarifado devem passar por auditorias periódicas do Núcleo de TI para garantir que seus softwares de gerenciamento de frotas e estoques não possuam vulnerabilidades que possam servir de porta de entrada para vírus na rede municipal.

5 SEGURANÇA FÍSICA DAS INSTALAÇÕES E GESTÃO DE DOCUMENTOS NÃO DIGITAIS

5.1 Controle de Acesso às Áreas Críticas de Infraestrutura de TI

A proteção dos ativos físicos de tecnologia é a primeira barreira para garantir a disponibilidade dos sistemas de saúde. O acesso aos locais de armazenamento de servidores e equipamentos de rede obedecerá aos seguintes níveis de restrição:

- **Data Center Central (Prédio da Secretaria de Saúde):** O ambiente onde residem os servidores principais e storages da SMS deve permanecer trancado e com acesso restrito. O controle de entrada será realizado por meio de crachás funcionais com tecnologia de aproximação ou, na ausência desta tecnologia, mediante controle rígido de chaves físicas, cuja retirada exige identificação em livro de protocolo oficial. O ambiente deve contar com monitoramento por câmera (CFTV) posicionado na entrada e sistema de climatização para garantir o resfriamento dos equipamentos. A entrada é restrita exclusivamente aos profissionais autorizados do Núcleo de TI.
- **Sala Técnica Hospitalar (Hospital Municipal):** Devido à operação ininterrupta e crítica do ambiente hospitalar, o hospital manterá uma sala de TI local para gerenciar a rede interna e garantir a comunicação com o sistema de prontuário. Esta sala deve permanecer trancada, com acesso restrito e chaves sob guarda da chefia de plantão administrativo ou analista local de TI.
- **Racks e Equipamentos Descentralizados (UPAs, UBSs e Vigilâncias):** Nas unidades de atendimento e nas Diretorias de Vigilância (onde há computadores alimentando os bancos de dados dos sistemas governamentais - SIS), os racks de rede, switches e roteadores devem ser instalados em caixas metálicas trancadas, posicionadas em salas de acesso restrito ao público (como coordenações ou salas administrativas), sendo proibida a instalação de fiação ou equipamentos expostos em corredores ou recepções.

5.2 Segurança Ambiental nas Áreas de Atendimento ao Público

A vulnerabilidade física nas recepções e guichês de triagem — onde atuam as equipes terceirizadas — exige a adoção de posturas preventivas contra o acesso visual ou físico de pessoas não autorizadas:

- **Posicionamento de Monitores:** Nas recepções das UPAs, UBSs, farmácias e laboratórios, as telas dos computadores devem ser posicionadas de forma que nenhum cidadão na fila de espera ou no balcão consiga visualizar as informações exibidas (dados cadastrais ou agendamentos). O uso de películas de privacidade nas telas é recomendado para locais de alta circulação.
- **Política de Mesa Limpa:** É expressamente proibido deixar fichas de acolhimento, prontuários de papel, receitas médicas, listagens de pacientes ou blocos de exames sobre os balcões de atendimento quando o funcionário se ausentar do posto, mesmo que por curto período. Todo documento físico contendo dados pessoais deve ser guardado em gavetas trancadas.
- **Guarda de Prontuários Físicos e Arquivos Mortos:** Os prontuários históricos em papel e pastas de arquivos administrativos devem ser arquivados em salas específicas, trancadas, com acesso limitado aos servidores autorizados e monitoradas pela equipe de vigilância patrimonial terceirizada.

5.3 Manuseio, Transporte e Descarte Seguro de Documentos

Para combater os riscos associados à baixa cultura de segurança no descarte de resíduos, a eliminação de informações em suporte físico deve seguir procedimentos que impeçam a sua recuperação:

- **Proibição de Descarte em Lixo Comum:** Fica terminantemente proibido o descarte de qualquer papel que contenha dados pessoais, diagnósticos, CIDs, prescrições, romaneios de entrega de insumos ou informações

funcionais de servidores diretamente no lixo comum ou de reciclagem sem antes passar por processo de fragmentação.

- **Uso de Fragmentadoras:** Todas as unidades de saúde, laboratórios municipais e diretorias administrativas devem ser equipadas com fragmentadoras de papel mecânicas (corte em partículas). Documentos sensíveis substituídos por processos digitais devem ser triturados imediatamente antes do descarte do resíduo.
- **Descarte de Equipamentos e Mídias de TI:** Computadores, HDs, fitas de backup ou pendrives inservíveis ou obsoletos não podem ser doados ou descartados como lixo eletrônico comum antes de passarem por um processo de desmagnetização ou destruição física da mídia de armazenamento, certificado pelo Núcleo de TI, para garantir que dados de saúde antigos não sejam recuperados por terceiros.

6 GESTÃO DE INCIDENTES DE SEGURANÇA E PLANOS DE CONTINUIDADE DE NEGÓCIOS

6.1 Identificação, Notificação e Resposta a Incidentes Cibernéticos

Nenhum ambiente tecnológico é totalmente imune a falhas ou ataques. Para mitigar os impactos de invasões, vazamentos de dados ou infecções por códigos maliciosos (*malwares/ransomware*), a Secretaria Municipal de Saúde (SMS) adota um fluxo de resposta rápida coordenado pelo Núcleo de TI e pelo Comitê (CSIP):

- **Isolamento Imediato de Dispositivos:** Caso qualquer colaborador ou terceirizado identifique um comportamento suspeito no computador (como arquivos sumindo, telas travadas com mensagens de resgate ou lentidão extrema após clicar em um link), a instrução imediata é desconectar o cabo de rede ou desligar o Wi-Fi do aparelho, sem desligar a máquina da tomada. Isso impede que o vírus se espalhe para os servidores centrais e para as demais UPAs e UBSs.
- **Abertura de Alerta Vermelho:** O Núcleo de TI manterá um canal de comunicação de emergência (ramal direto e sistema de chamados prioritário) exclusivo para relatos de suspeitas de incidentes de segurança.
- **Contenção e Erradicação:** A equipe técnica isolará o segmento de rede afetado, aplicará ferramentas de varredura e remoção da ameaça e, se necessário, suspenderá temporariamente os acessos externos (como conexões de laboratórios conveniados ou acessos via VPN) até que a integridade do ambiente seja restabelecida.

6.2 Fluxo Legal de Comunicação de Vazamento de Dados

Em caso de incidentes comprovados que resultem em acessos não autorizados, destruição, perda ou alteração de dados pessoais de pacientes ou

servidores, a SMS acionará o Encarregado de Dados (DPO) para cumprir as obrigações legais perante a Lei Geral de Proteção de Dados:

- **Relatório Técnico Preliminar:** O Núcleo de TI emitirá, em até 24 horas do início do incidente, um relatório detalhando a natureza dos dados afetados, o número estimado de pacientes envolvidos e as medidas de segurança que estavam ativas no momento da ocorrência.
- **Notificação à ANPD:** O DPO formalizará a comunicação do incidente à Autoridade Nacional de Proteção de Dados (ANPD) dentro do prazo legal, descrevendo os riscos decorrentes do vazamento e as ações adotadas para mitigar os danos.
- **Comunicação aos Titulares (Cidadãos):** Caso o vazamento envolva dados altamente sensíveis (como históricos de prontuários ou diagnósticos médicos) que possam gerar prejuízos morais ou discriminação aos pacientes, a prefeitura emitirá comunicados públicos oficiais em seus portais e, se possível, notificações diretas aos afetados, prestando orientações sobre como se proteger contra fraudes de engenharia social.

6.3 Plano de Continuidade Operacional em Saúde

Os serviços de saúde de urgência e emergência não podem ser paralisados por falhas de infraestrutura de TI. Se o aplicativo de gestão em saúde ficar inacessível por quedas de energia prolongadas, rompimento de cabos de internet do município ou ataques de negação de serviço, a SMS institui as seguintes regras de contingência:

- **Formulários Físicos Padronizados (Blocos de Contingência):** Todas as UPAs, UBSs, farmácias e o Hospital Municipal devem manter em estoque estratégico blocos impressos e padronizados de "Fichas de Acolhimento/Triagem", "Prontuários de Evolução Clínica Célula", "Guias de Encaminhamento" e "Receitas". O atendimento médico e de enfermagem migrará imediatamente para o preenchimento manual no papel.
- **Controle de Dispensação Manual na Farmácia:** A entrega de medicamentos, tanto nas farmácias das UBSs quanto no Hospital, será feita

mediante retenção de uma via física da receita médica assinada e carimbada pelo profissional de saúde. O servidor anotarà manualmente o lote do medicamento entregue no verso da receita para posterior controle de estoque.

- **Comunicação Telefônica:** Sem o sistema eletrônico de chamadas, a triagem (Protocolo de Manchester) e a convocação dos pacientes para os consultórios serão feitas por avisos sonoros manuais ou painéis analógicos. A comunicação entre o laboratório municipal e as alas hospitalares para resultados urgentes de exames (como hemogramas e gasometrias) será realizada via telefone.

6.4 Processo de Retroalimentação e Recuperação do Sistema Pós-Incidente

Após a estabilização das conexões elétricas ou lógicas e a autorização de reabertura do sistema pelo Núcleo de TI, a rede de saúde passará pelo processo de transição para retornar à normalidade digital:

- **Validação de Backups:** Antes de liberar o aplicativo de saúde para uso geral, a equipe de TI validará a integridade dos bancos de dados, garantindo que o retorno ao ponto anterior ao incidente ocorra sem arquivos corrompidos ou perdas de dados históricos.
- **Digitação Compulsória do Período de Contingência (Retroalimentação):** Todas as informações clínicas, receitas e cadastros coletados manualmente nos papéis de contingência durante o período em que o sistema ficou fora do ar deverão ser obrigatoriamente digitados no sistema em até 5 dias úteis após o retorno da rede. A responsabilidade pela digitação é da chefia administrativa de cada unidade, que organizará forças-tarefa em horários de menor movimento para que o histórico do prontuário do cidadão não fique com "buracos" de informação.
- **Destruição das Fichas de Papel:** Uma vez que os dados foram integralmente transcritos para o prontuário digital eletrônico, as fichas e rascunhos de papel utilizados na contingência deverão ser descartados

seguindo as regras de trituração mecânica descritas na Seção 5 deste documento, evitando o acúmulo de arquivos físicos paralelos vulneráveis.

7 GESTÃO DE FORNECEDORES, TERCEIROS E CONTRATOS

7.1 Requisitos de Segurança para o Fornecedor do Aplicativo de Saúde

A empresa detentora do software de gestão em saúde possui acesso irrestrito à infraestrutura lógica e ao banco de dados que armazena os prontuários eletrônicos do município. Portanto, a manutenção do contrato de prestação de serviços técnicos fica condicionada ao cumprimento rigoroso dos seguintes requisitos:

- **Rastreabilidade de Perfis de "Administrador Geral":** Os técnicos, analistas e programadores da empresa fornecedora que realizarem manutenções, correções de bugs ou atualizações no sistema devem utilizar credenciais individuais e nominais. Fica terminantemente proibido o uso de senhas genéricas de suporte (como "admin" ou "suporte_empresa"). Todas as ações desses profissionais devem ser registradas em arquivos de *log* auditáveis, sob guarda da Secretaria Municipal de Saúde (SMS).
- **Segurança do Desenvolvimento e Correção de Vulnerabilidades:** A desenvolvedora deve garantir que o aplicativo passe por testes periódicos de intrusão (*pentests*) e correções de falhas de segurança do código. Sempre que uma vulnerabilidade for identificada, a empresa é obrigada a lançar pacotes de correção (*patches*) emergenciais para proteger o banco de dados municipal contra invasões.
- **Criptografia no Armazenamento (Dados em Repouso):** O fornecedor deve comprovar que os dados sensíveis dos pacientes (especialmente diagnósticos, exames e históricos clínicos) são armazenados no banco de dados utilizando criptografia forte, de modo que, mesmo em caso de furto físico dos servidores ou clonagem dos arquivos de backup, as informações permaneçam ilegíveis para terceiros.

7.2 Responsabilidade Solidária de Empresas de Serviços Terceirizados

O preenchimento de fichas de atendimento, a triagem inicial e o transporte de insumos médicos são realizados por colaboradores de empresas prestadoras de serviços terceirizados. Para garantir o alinhamento com a cultura de segurança da SMS, instituem-se as seguintes regras contratuais:

- **Anexo de Confidencialidade e LGPD nos Editais:** Todos os novos editais de licitação e contratos vigentes para a prestação de serviços de recepção, portaria, limpeza e logística devem conter, obrigatoriamente, um Anexo Técnico de Segurança da Informação. As empresas contratadas assumem responsabilidade civil e solidária por quaisquer vazamentos de dados causados por negligência ou má conduta de seus funcionários.
- **Treinamento de Integração Obrigatório:** A empresa terceirizada fica obrigada a submeter 100% de seus colaboradores escalados para atuar nas UPAs, UBSs e demais unidades desta secretaria ao treinamento de segurança da informação promovido pelo Núcleo de TI da prefeitura antes que eles recebam suas credenciais de acesso aos sistemas.
- **Notificação de Desligamento de Pessoal:** Em caso de demissão, transferência ou afastamento de um funcionário terceirizado, a empresa prestadora deve notificar o Núcleo de TI da SMS em até, no máximo, 24 horas úteis para que o usuário e a senha daquele colaborador sejam sumariamente revogados, evitando acessos de revanche ou uso indevido de credenciais ativas.

7.3 Segurança de Dados no Compartilhamento com Laboratórios e Clínicas Conveniadas

As entidades privadas parceiras que recebem ordens de exames e devolvem laudos diagnósticos à SMS passam a atuar como Operadoras de Dados do município, devendo seguir os critérios técnicos estabelecidos pela governança municipal:

- **Homologação de APIs de Integração:** O envio de requisições de exames e o recebimento de resultados digitais só poderão ocorrer por meio de conexões diretas entre sistemas homologadas pelo Núcleo de TI. Fica

proibida qualquer integração automatizada que não utilize protocolos seguros de comunicação (HTTPS) e chaves de validação criptográficas.

- **Segurança nos Termos de Convênio:** Os termos de credenciamento e convênio com hospitais filantrópicos, laboratórios de análises clínicas e clínicas de imagem privadas devem incluir cláusulas que vedem a utilização dos dados cadastrais dos munícipes do SUS para fins comerciais, publicitários ou de oferta de serviços privados de saúde, sob pena de rescisão imediata do convênio e aplicação de sanções legais.

7.4 Direito de Auditoria e Fiscalização Contratual (*Right to Audit*)

A secretaria, assim como o município, resguarda para si o poder-de-dever de fiscalizar a eficiência das medidas de proteção adotadas por seus parceiros comerciais, instituindo as seguintes práticas de controle:

- **Inspecções Programadas e Amostrais:** O Núcleo de TI, em conjunto com o Encarregado de Dados (DPO), poderá realizar auditorias anuais ou vistorias amostrais sem aviso prévio nas dependências das empresas de logística terceirizada (Almoxarifado Central) e nos portais de laudos dos laboratórios conveniados, avaliando o cumprimento das políticas de mesa limpa, descarte de papel e segurança física.
- **Exigência de Relatórios de Conformidade:** A SMS poderá exigir, a qualquer tempo, que a empresa desenvolvedora do software de saúde ou a prestadora de serviços de TI apresentem relatórios técnicos atualizados de varredura de vulnerabilidades ou certificações de segurança (como a ISO/IEC 27001), como contrapartida para a renovação contratual ou liberação de pagamentos de medições de serviços.

8 MONITORAMENTO, AUDITORIA E TRILHA DE LOGS INTERNOS

8.1 Obrigatoriedade do Registro de Eventos (Trilha de Auditoria)

Este regulamento visa garantir a rastreabilidade absoluta e a irrecusabilidade de todas as ações executadas pelos usuários dentro dos sistemas de saúde do município, permitindo identificar com precisão o autor de qualquer consulta, alteração ou extração de dados pessoais e sensíveis.

O software de gestão de saúde e os sistemas correlatos operados na rede municipal de saúde devem gerar, obrigatoriamente, registros de auditoria (*logs*) automatizados para todas as transações que envolvam dados sensíveis de cidadãos. Fica determinado que o sistema deve registrar, de forma indissociável, os seguintes metadados para cada evento:

- **Identificação do Agente:** O usuário único (login/CPF) que realizou a ação, associado ao seu respectivo cargo e unidade de saúde de lotação.
- **Identificação do Paciente:** O número do Cartão Nacional de Saúde (CNS) ou CPF do cidadão cujo prontuário ou cadastro foi acessado.
- **Carimbo de Tempo (*Timestamp*):** A data e a hora exatas do evento, sincronizadas obrigatoriamente com o Horário Oficial de Brasília por meio do protocolo NTP (*Network Time Protocol*), impedindo adulterações manuais de horário nos servidores.
- **Endereço IP e Terminal de Origem:** O endereço lógico (IP) e o nome do computador de onde partiu a requisição na rede interna.
- **Ação Executada (Tipo de Evento):** A categorização exata da operação, que se classifica estritamente em:
 1. *Visualização/Consulta:* Simples leitura de prontuário, ficha de atendimento ou resultado de exame na tela.
 2. *Inserção/Criação:* Adição de novas informações clínicas, evolução médica ou agendamentos.

3. *Alteração/Modificação*: Edição de dados pré-existentes (deixando salvo o valor anterior e o novo valor).
4. *Exclusão/Deleção*: Apagamento de registros (procedimento restrito e condicionado à justificativa sistêmica).
5. *Exportação/Impressão*: Geração de arquivos PDF, planilhas Excel ou ordens físicas de impressão de prontuários e relatórios gerenciais.

8.2 Retenção, Guarda e Imutabilidade dos Arquivos de Log

Fica estabelecido o período mínimo de armazenamento dos registros de acesso e auditoria em conformidade com a legislação federal vigente, devendo ser implantadas defesas técnicas que impeçam a alteração ou destruição criminosa desses registros por usuários internos.

Procedimentos e Regras Técnicas:

- **Prazo de Retenção Mínima**: Em estrito cumprimento ao Artigo 15 da Lei Federal nº 12.965/2014 (Marco Civil da Internet) e considerando a natureza perecível dos dados de saúde, todos os logs de auditoria de acesso a aplicações de prontuário eletrônico e bancos de dados de exames devem ser armazenados pelo prazo mínimo e obrigatório de 6 (seis) meses, contados a partir da data de geração do registro.
- **Armazenamento Segregado (Servidor de Logs)**: Os arquivos de log não podem ficar armazenados no mesmo servidor físico ou virtual onde roda a aplicação de saúde ou o banco de dados principal. Eles devem ser direcionados em tempo real para um servidor centralizado de logs isolado, mitigando o risco de que uma invasão ao sistema principal resulte no apagamento das trilhas que revelam a invasão.
- **Princípio da Imutabilidade (*Write Once, Read Many - WORM*)**: Os arquivos de log consolidados devem receber, ao fim de cada ciclo diário, uma assinatura digital baseada em funções de dispersão criptográfica (como o algoritmo SHA-256). Isso garante que qualquer tentativa de alteração posterior de uma única linha de log quebre a integridade do arquivo, alertando imediatamente a equipe de segurança.

- **Restrição de Acesso aos Logs:** O acesso de leitura aos arquivos de log históricos é restrito exclusivamente ao DPO e ao Administrador Chefe (Gerente) do Núcleo de TI, mediante justificativa fundamentada. Nenhum operador de suporte terceirizado ou programador do sistema de saúde poderá ter permissões de escrita ou exclusão sobre a base de dados de logs.

8.3 Rotinas de Análise e Monitoramento de Anomalias

Fica determinada a implementação de ferramentas automatizadas de triagem de logs para a detecção precoce de acessos anômalos, vazamentos de dados ou uso indevido do sistema por agentes públicos, com o objetivo de mitigar danos ao erário e à privacidade dos cidadãos.

Procedimentos e Regras Técnicas: O Núcleo de TI não deve atuar apenas de forma reativa após a ocorrência de um incidente. Fica instituída a rotina automatizada de geração de alertas de segurança com base em gatilhos de comportamento anômalo de usuários. Os seguintes cenários devem disparar um alerta crítico imediato para o e-mail institucional da governança de TI:

- **Acesso Fora do Horário de Expediente:** Disparo de alerta quando uma credencial de nível assistencial (técnico de enfermagem, recepcionista ou médico) acessar o sistema de saúde entre as 23h e as 05h, exceto para profissionais comprovadamente escalados em regime de plantão na UPA 24h ou no Hospital Municipal.
- **Volume Incomum de Consultas (Varredura de Prontuários):** Emissão de alerta quando um único usuário visualizar ou exportar mais de 30 (trinta) prontuários médicos de pacientes distintos em um intervalo inferior a 60 minutos, comportamento incompatível com a rotina padrão de atendimento clínico individualizado.
- **Acessos Simultâneos Coincidentes (Concorrência de Credencial):** Alerta gerado quando o mesmo login e senha for detectado realizando requisições a partir de endereços IP de subredes ou localizações físicas diferentes ao mesmo tempo (evidência clara de compartilhamento ilegal de senha).

8.4 Prerrogativa de Investigação e Quebra de Sigilo Interno

Esta norma estabelece o amparo legal e procedimental que confere à Administração Pública o direito de auditar, inspecionar e fiscalizar o uso que os agentes públicos fazem das ferramentas computacionais e dos dados custodiados pelo município, conforme os seguintes procedimentos:

Procedimentos e Regras Técnicas:

- **Natureza Pública das Ferramentas:** Fica expressamente estabelecido que os computadores, a rede lógica, o acesso à internet corporativa, as contas de e-mail institucional e, fundamentalmente, as credenciais de acesso aos softwares de gestão de saúde fornecidos pela Secretaria Municipal de Saúde são ferramentas de trabalho de propriedade exclusiva do Município.
- **Ausência de Expectativa de Privacidade Laboral:** O servidor público, ao aceitar o Termo de Ciência e Responsabilidade (conforme detalhado na seção de Cultura de Segurança), declara estar ciente de que não há expectativa de privacidade no uso dos bens públicos e sistemas institucionais. Toda e qualquer atividade por ele desempenhada nesses ambientes digitais está sujeita à fiscalização permanente.
- **Abertura de Procedimento de Auditoria Interna:** Havendo suspeita fundamentada, denúncia na Ouvidoria Municipal ou indício de vazamento gerado pelos alertas de anomalia (Subtópico 8.3), o DPO ou a Secretária de Saúde poderá determinar oficialmente a abertura de um procedimento de auditoria computacional focado em um determinado servidor ou grupo de usuários.
- **Legalidade da Extração de Provas:** O relatório técnico contendo a extração dos logs de auditoria, as telas visualizadas, os comandos executados e o histórico de tráfego do servidor investigado será assinado digitalmente pelos analistas do NTI. Este relatório constituirá prova técnica e documental robusta, dotada de presunção de legitimidade, a qual será encaminhada diretamente à Controladoria-Geral do Município para instruir o Processo Administrativo Disciplinar (PAD), sem prejuízo do envio de cópia ao Ministério

Público para apuração de atos de improbidade administrativa e crimes previstos no Código Penal.

9 DIRETRIZES DE CONFORMIDADE, VIOLAÇÕES E PENALIDADES

9.1 Finalidade e Objetivo

Estabelecer as consequências administrativas, civis e penais decorrentes do descumprimento das normas estabelecidas nesta Política Unificada de Segurança e Privacidade da Informação. Esta seção visa garantir a responsabilidade individual de todos os colaboradores, mitigar os riscos de vazamento de informações, coibir o uso indevido de sistemas e combater a baixa cultura de segurança através de ações pedagógicas e punitivas.

9.2 Da Obrigatoriedade da Ciência (Garantia de Aplicabilidade)

As penalidades previstas nesta política só serão aplicadas mediante a comprovação de que o colaborador tinha pleno conhecimento das regras. Para tanto, a Secretaria Municipal de Saúde determina:

1. **Termo de Ciência e Responsabilidade (TCR):** Nenhum servidor, estagiário, terceirizado ou prestador de serviço receberá credenciais de acesso aos sistemas (computadores, prontuários eletrônicos, e-mails) sem a assinatura prévia, física ou digital, do TCR.
2. **Divulgação e Treinamento Contínuo:** Esta política ficará permanentemente disponível na Intranet do município. Serão realizadas campanhas semestrais de conscientização sobre segurança da informação para combater a baixa cultura de segurança.
3. **Reciclagem Obrigatória:** Qualquer alteração ou atualização desta política (mudança de versão) exigirá uma nova notificação oficial a todos os usuários via e-mail institucional ou sistema de RH.

9.3 Classificação das Infrações

As violações a esta política são classificadas de acordo com a gravidade da conduta e o impacto potencial ou real aos dados dos cidadãos e aos sistemas da Secretaria:

- **Infração Leve:** Condutas que não geram dano imediato à confidencialidade dos dados, mas violam as boas práticas.
 - *Exemplos:* Deixar o computador desbloqueado ao se afastar da mesa; não atualizar a senha na data recomendada.
- **Infração Média:** Condutas que expõem os sistemas a riscos elevados ou que utilizam os recursos públicos de forma indevida.
 - *Exemplos:* Compartilhar a senha pessoal com colegas de setor ou estagiários; utilizar e-mail institucional para cadastros em sites de compras/lazer pessoais; realizar o descarte de documentos impressos com dados sem trituração prévia.
- **Infração Grave:** Condutas que resultam em vazamento de informações, acesso não autorizado por nível hierárquico, dano doloso aos sistemas ou uso indevido de dados sensíveis (LGPD).
 - *Exemplos:* Acessar prontuários médicos de cidadãos sem justificativa assistencial (curiosidade ou perseguição); vazar relatórios financeiros ou dados de licitações; extrair cópias de bancos de dados da prefeitura para dispositivos pessoais (pendrives, nuvem particular); desativar mecanismos de criptografia ou segurança deliberadamente.

9.4 Das Penalidades Aplicáveis

O descumprimento das normas sujeitará o infrator às seguintes penalidades, aplicadas de forma isolada ou cumulativa, respeitando-se o devido processo legal, o contraditório e a ampla defesa, conforme o Estatuto dos Servidores Públicos Municipais:

9.4.1 Para Servidores Públicos (Estatutários e Comissionados)

1. **Advertência Escrita:** Aplicada em casos de infrações leves ou na primeira reincidência de práticas inadequadas de baixa cultura de segurança.

2. **Suspensão Administrativa:** Aplicada em casos de infrações médias ou reincidência em infrações leves, com perda da remuneração pelos dias de suspensão.
3. **Demissão / Destituição de Cargo em Comissão:** Aplicada em casos de infrações graves, como vazamento doloso de dados sensíveis dos cidadãos, uso indevido de sistemas para obter vantagem ou cometimento de crimes cibernéticos (conforme a Lei Carolina Dieckmann e LGPD).

9.4.2 Para Estagiários

1. **Advertência Verbal/Escrita:** Para infrações leves, com notificação formal à instituição de ensino supervisora.
2. **Rescisão Imediata do Termo de Compromisso de Estágio:** Aplicada em casos de infrações médias (como compartilhamento de senhas) ou graves (vazamento de informações).

9.4.3 Para Empresas Terceirizadas e Prestadores de Serviço

1. **Notificação Formal:** Aplicada à empresa contratada exigindo a substituição imediata do funcionário terceirizado que violou as regras leves ou médias.
2. **Processo Administrativo Sancionatório (PAS):** Em caso de vazamento de dados gerado por falha ou dolo da contratada, o município aplicará multas contratuais, rescisão de contrato e impedimento de licitar com a Administração Pública.

9.5 Responsabilização Civil e Penal

Independentemente das sanções administrativas descritas acima, a Secretaria Municipal de Saúde, por meio da Procuradoria Jurídica do Município, acionará as autoridades competentes para que o infrator responda judicialmente:

- **Civilmente:** Ressarcimento de danos financeiros causados ao erário público ou indenizações a cidadãos que tiveram seus dados vazados.

- **Penalmente:** Representação criminal perante a Polícia Civil/Ministério Público pelos crimes de invasão de dispositivo informático, violação de sigilo profissional ou prevaricação.

10 DISPOSIÇÕES FINAIS

10.1 Atualização e Revisão Periódica

Esta Política de Segurança e Privacidade da Informação não é um documento estático. Ela deverá ser revisada ordinariamente a cada **24 (doze) meses** pelo Núcleo de Tecnologia da Informação, através do Comitê de Segurança da Informação e Privacidade da Secretaria, ou extraordinariamente a qualquer momento, caso surjam novas ameaças, alterações na legislação federal (como atualizações na LGPD) ou mudanças significativas na infraestrutura tecnológica do município.

10.2 Casos Omissos

Os casos omissos ou situações excepcionais não previstas nesta política serão analisados e deliberados conjuntamente pelo Comitê de Segurança da Informação e Privacidade, pela Assessoria Jurídica e pelo Gabinete da Secretária Municipal de Saúde.

ANEXO A – Modelo de Termo de Ciência e Responsabilidade

TERMO DE CIÊNCIA, CONFIDENCIALIDADE E RESPONSABILIDADE

Por este instrumento, eu, [Nome Completo do Servidor/Colaborador], inscrito(a) sob o CPF nº [Inserir CPF], no cargo/função de [Inserir Cargo/Função], lotado(a) na Secretaria Municipal de Saúde, declaro para os devidos fins de direito que:

1. Tomei pleno conhecimento, fui instruído(a) e recebi cópia integral da Política Unificada de Segurança e Privacidade da Informação vigente nesta instituição.
2. Compreendo que o acesso aos sistemas de informação e dados de saúde dos cidadãos deve ser pautado pela finalidade estrita das minhas funções atribuídas, sendo vedada qualquer consulta de dados para fins pessoais ou de terceiros sem justificativa legal/assistencial.
3. Declaro estar ciente de que as minhas credenciais de acesso (usuário, senha e chaves de duplo fator) são de uso pessoal, exclusivo e intransferível, sendo eu o(a) único(a) responsável por qualquer alteração, inserção ou exclusão de dados realizada sob a minha identidade digital.
4. Comprometo-me a manter total sigilo e confidencialidade sobre quaisquer dados pessoais sensíveis (como prontuários, exames e históricos médicos) aos quais eu tenha acesso, abstendo-me de divulgá-los, fotografá-los ou compartilhá-los em redes sociais ou canais de comunicação não institucionais.
5. Estou ciente de que o descumprimento de qualquer norma ou procedimento previsto nesta Política constitui infração disciplinar, sujeitando-me às penalidades administrativas de Advertência, Suspensão ou Demissão/Rescisão Contratual, sem prejuízo da responsabilidade civil e criminal decorrente da violação de sigilo e da Lei Geral de Proteção de Dados (Lei nº 13.709/2018).

[Cidade - UF], [Dia] de [Mês] de [Ano].

Assinatura do Servidor / Colaborador

Assinatura da Chefia Imediata / Recursos Humanos

ANEXO B – Glossário Técnico e Legal

1. Termos Técnicos e Tecnológicos

- **API (Interface de Programação de Aplicações):** Mecanismo de interoperabilidade segura entre sistemas (ex: integração com o e-SUS).
- **Acesso Lógico:** Interação eletrônica por meio de credenciais individuais (CPF/Senha), distinguindo-se do acesso físico.
- **Backup:** Salvaguarda técnica para recuperação do sistema em caso de indisponibilidade ou ataques.
- **Criptografia:** Processamento matemático para proteção de dados em repouso e em trânsito.
- **Firewall:** Filtro de tráfego de rede para bloqueio de acessos não corporativos.
- **Homologação Geográfica e Digital:** Mecanismo de ativação por certificados digitais que proíbe acessos externos fora do padrão.
- **Imutabilidade de Logs (WORM):** Uso de algoritmos de dispersão hash (SHA-256) para impedir alteração de históricos.
- **Log de Auditoria (Trilha de Auditoria):** Metadados rastreáveis (Agente, Paciente, *Timestamp*, IP e Ação).
- **Malware / Ransomware:** Vetores de ataque hostil que ameaçam a integridade dos bancos de dados de saúde.
- **MFA (Autenticação Multifator):** Camada dupla de autenticação exigida para conexões externas via VPN.
- **NTP (Network Time Protocol):** Sincronização cronológica com o Horário Oficial de Brasília.
- **Phishing / Engenharia Social:** Técnicas de manipulação psicológica que exploram a baixa cultura de segurança.
- **Princípio do Menor Privilégio:** Limitação de acessos de pastas e funções com base na necessidade estrita do cargo.
- **VPN (Rede Privada Virtual):** Canal criptografado para tráfego e acessos administrativos remotos autorizados.

2. Termos Legais, Regulatórios e Administrativos

- **ANPD (Autoridade Nacional de Proteção de Dados):** Órgão federal fiscalizador e sancionador da LGPD.
- **CNES (Cadastro Nacional de Estabelecimentos de Saúde):** Base auditada e validada pela regulação da SMS.
- **Controlador de Dados:** A SMS, órgão público a quem competem as decisões sobre o tratamento de dados (*Art. 5º, VI, LGPD*).
- **Dados Pessoais Sensíveis:** Prontuários, diagnósticos (CID), históricos de farmácia e exames (*Art. 5º, II, LGPD*).
- **DPO (Encarregado pelo Tratamento de Dados):** Canal oficial entre o município, cidadãos e ANPD (*Art. 5º, VIII, LGPD*).
- **Lei Carolina Dieckmann (Lei 12.737/2012):** Tipificação penal de crimes cibernéticos e invasão de dispositivos.
- **LGPD (Lei Geral de Proteção de Dados - Lei 13.709/2018):** Vetor central que regula o tratamento dos dados no SUS.
- **Marco Civil da Internet (Lei 12.965/2014):** Base jurídica (*Art. 15*) que exige a guarda de logs por no mínimo 6 meses.
- **Operador de Dados:** Empresas terceirizadas, fornecedores de software e clínicas conveniadas (*Art. 5º, VII, LGPD*).
- **PAD (Processo Administrativo Disciplinar):** Rito para aplicação de sanções administrativas aos servidores públicos.
- **Responsabilidade Solidária:** Vinculação cível que obriga empresas terceirizadas a responderem junto com o município em caso de incidentes causados por suas equipes.
- **Right to Audit (Direito de Auditoria):** Prerrogativa contratual da administração de vistoriar e fiscalizar terceiros sem aviso prévio.
- **RIPD (Relatório de Impacto à Proteção de Dados):** Documento metodológico de gerenciamento de riscos ao cidadão (*Art. 5º, XVII, LGPD*).
- **TCR (Termo de Ciência e Responsabilidade):** Documento mandatório para remoção de expectativa de privacidade laboral e validação das penalidades.

3. Normas Técnicas Referenciadas

- **ABNT NBR ISO 31000:** Diretrizes macro institucionais de Gestão de Riscos.

- **ABNT NBR ISO/IEC 27005:** Gestão de Riscos focada em segurança da informação e infraestrutura de TI.
- **ABNT NBR ISO/IEC 27557:** Extensão da ISO 31000 focada especificamente nos impactos e riscos à privacidade organizacional e do cidadão.
- **PPSI 2.0 (Programa de Privacidade e Segurança da Informação):** Parâmetro de maturidade e governança cibernética digital do Governo Federal.
- **NIST SP 800-88 (Guidelines for Media Sanitization):** Diretriz técnica internacional para a sanitização, descarte e destruição segura de mídias de armazenamento de dados.

REFERÊNCIAS

ASSOCIAÇÃO BRASILEIRA DE NORMAS TÉCNICAS. **ABNT NBR ISO 31000:**

Gestão de riscos - Diretrizes. 2. ed. Rio de Janeiro: ABNT, 2018. 17 p.

ASSOCIAÇÃO BRASILEIRA DE NORMAS TÉCNICAS. **ABNT NBR ISO/IEC 27005:**

Segurança da informação, segurança cibernética e proteção à privacidade -

Orientações para gestão de riscos de segurança da informação. 4. ed. Rio de

Janeiro: ABNT, 2023. 75 p.

BRASIL. Autoridade Nacional de Proteção de Dados. **Guia orientativo:** atuação do encarregado pelo tratamento de dados pessoais. Brasília, DF: ANPD, 2024.

Disponível em:

<https://www.gov.br/anpd/pt-br/assuntos/noticias/anpd-lanca-guia-sobre-atuacao-do-encarregado>. Acesso em: 09 jun. 2026.

BRASIL. Autoridade Nacional de Proteção de Dados. **Guia orientativo:** tratamento de dados pessoais pelo Poder Público. Versão 2.0. Brasília, DF: ANPD, 2023.

Disponível em:

https://www.gov.br/anpd/pt-br/centrais-de-conteudo/materiais-educativos-e-publicacoes/guia_orientativo_tratamento_de_dados_pessoais_pelo_poder_publico. Acesso em: 09 jun. 2026.

BRASIL. Lei nº 12.527, de 18 de novembro de 2011. Regula o acesso a informações previsto no inciso XXXIII do art. 5º, no inciso II do § 3º do art. 37 e no § 2º do art. 216 da Constituição Federal. Brasília: Presidência da República, [2011].

Disponível em:

http://www.planalto.gov.br/ccivil_03/_ato2011-2014/2011/lei/l12527.htm. Acesso em: 10 jun. 2026.

BRASIL. Lei nº 13.709, de 14 de agosto de 2018. Lei Geral de Proteção de Dados Pessoais (LGPD). Brasília: Presidência da República, [2018]. Disponível em:

http://www.planalto.gov.br/ccivil_03/_ato2015-2018/2018/lei/l13709.htm. Acesso em: 10 jun. 2026.

BRASIL. Ministério da Gestão e da Inovação em Serviços Públicos. Secretaria de Governo Digital. Diretoria de Privacidade e Segurança da Informação. **Guia do Framework de Privacidade e Segurança da Informação:** Programa de Privacidade e Segurança da Informação (PPSI 2.0). Versão 1.2. Brasília: SGD/MGI, 30 jan. 2026. Disponível em: <https://www.gov.br/governodigital/pt-br/privacidade-e-seguranca/ppsi-2.0>. Acesso em: 02 jun. 2026.

BRASIL. Ministério da Gestão e da Inovação em Serviços Públicos. Secretaria de Governo Digital. Diretoria de Privacidade e Segurança da Informação. **Guia Complementar de Segurança da Informação para Computação em Nuvem:** Programa de Privacidade e Segurança da Informação (PPSI 2.0). Versão 1.1. Brasília, DF: MGI/SGD, nov. 2025. 48 p. Disponível em: <https://www.gov.br/governodigital/pt-br/privacidade-e-seguranca/ppsi-2.0>. Acesso em: 02 jun. 2026.

BRASIL. Ministério da Gestão e da Inovação em Serviços Públicos. Secretaria de Governo Digital. Diretoria de Privacidade e Segurança da Informação. **Guia para Elaboração de Políticas, Normas e Procedimentos:** Programa de Privacidade e Segurança da Informação (PPSI 2.0). Versão 1.0. Brasília, DF: MGI, 13 mai. 2026. 32 p. Disponível em: <https://www.gov.br/governodigital/pt-br/privacidade-e-seguranca/ppsi-2.0>. Acesso em: 02 jun. 2026.

BRASIL. Ministério da Gestão e da Inovação em Serviços Públicos. Secretaria de Governo Digital. Diretoria de Privacidade e Segurança da Informação. **Modelo de Política de Proteção de Dados Pessoais:** Programa de Privacidade e Segurança da Informação (PPSI). Versão 1.1. Brasília, DF: MGI/SGD, out. 2024. 27 p. Disponível em: <https://www.gov.br/governodigital/pt-br/privacidade-e-seguranca/framework-guias-e-modelos>. Acesso em: 02 jun. 2026.

BRASIL. Ministério da Gestão e da Inovação em Serviços Públicos. Secretaria de Governo Digital. Diretoria de Privacidade e Segurança da Informação. **Modelo de**

Política de Segurança da Informação: Programa de Privacidade e Segurança da Informação (PPSI 2.0). Versão 1.0. Brasília, DF: MGI/SGD, 13 maio 2026. 9 p.

Disponível em:

<https://www.gov.br/governodigital/pt-br/privacidade-e-seguranca/ppsi-2.0>. Acesso em: 03 jun. 2026.

BRASIL. Ministério da Saúde. Secretaria de Vigilância em Saúde e Ambiente.

Departamento de Análise Epidemiológica e Vigilância de Doenças Não

Transmissíveis. **Guia Básico para Privacidade de Dados e Segurança da**

Informação [PDF]. Brasília: Ministério da Saúde, 2025. 44 p. Disponível em:

https://bvsms.saude.gov.br/bvs/publicacoes/guiabasico_privacidade_seguranca_informacao.pdf. Acesso em: 03 jun. 2026.

BRASIL. Secretaria Especial de Desburocratização, Gestão e Governo Digital. **Guia**

de boas práticas: Lei Geral de Proteção de Dados (LGPD): implementação na

administração pública federal [PDF]. Versão 2.0. Brasília: Governo Federal, ago.

2020. Disponível em:

https://www.gov.br/governodigital/pt-br/privacidade-e-seguranca/guias/guia_lgpd.pdf.

Acesso em: 09 jun. 2026.

FIOCRUZ. Fundação Oswaldo Cruz. **Política de Segurança da Informação e**

Comunicações (POSIC): e normas complementares. Versão 1.11. Rio de Janeiro,

2012. Disponível em: <https://tic.fiocruz.br/documento/politicas>. Acesso em: 09 jun.

2026.

INTERNATIONAL ORGANIZATION FOR STANDARDIZATION; INTERNATIONAL

ELECTROTECHNICAL COMMISSION. **ISO/IEC 27000:** Information Technology

Security Techniques - Information security management systems - Overview and

vocabulary. [S. l.]: ISO/IEC, 2020.

MARANHÃO (Estado). Secretaria de Estado da Saúde. Escola de Saúde Pública do

Estado do Maranhão. **Política de privacidade** [PDF]. São Luís: ESP/MA. Disponível

em:

https://escola.saude.ma.gov.br/pluginfile.php/1/tool_policy/policydocumentssummary/1

6/Pol%C3%ADtica_de_Privacidade_Campus_ESP-MA.pdf. Acesso em: 10 jun. 2026.

NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY. **NIST SP 800-88 rev. 2: Guidelines for Media Sanitization**. Gaithersburg: NIST, 2025. Disponível em: <https://csrc.nist.gov/pubs/sp/800/88/r2/final>. Acesso em: 10/06/2026.

SANTA CATARINA. Centro de Informática e Automação do Estado de Santa Catarina (CIASC). Comitê Gestor de Segurança da Informação. **Política de Segurança da Informação**. Versão 2.4. Florianópolis: CIASC, 29 out. 2020. 32 p. Disponível em: <https://www.ciasc.sc.gov.br/download/politica-de-seguranca-da-informacao-2020-3/>. Acesso em: 08 jun. 2026.

SES-MT. Secretaria de Estado de Saúde de Mato Grosso. **Política de Privacidade e Proteção de Dados Pessoais - PPDP**. Mato Grosso, 2021. Disponível em: <https://www.saude.mt.gov.br/unidade/comites-setoriais-de-protecao-de-dados-e-de-seguranca-da-informacao/457/politicas-da-ses>. Acesso em: 09 jun. 2026.